Helium - Technical Specification v3.0

Module 2: Security & Compliance Architecture

Document Version: 3.1 (Customer Preview Edition)
Date: November 2025
Owner: WestMetro Limited
Classification: Confidential - Prospective Customers

Document Version History

Version	Date	Changes
1.0	Oct 2024	Initial security specification
2.0	Oct 2025	Enhanced encryption, added enterprise alternatives
3.0	Nov 2025	Updated post-November 2025 mandate; added pricing for enterprise options; clarified zero-knowledge architecture
3.1	Nov 2025	Condensed for scannability; added one-page overview; updated edition names (Standard/Professional/Enterprise); added email security; expanded SQL injection and queue security; complete add-ons overhaul

Helium Editions and Security Version Mappings

This security architecture applies to all Helium editions with tier-specific features:

EDITION	SECURITY FEATURES
Helium Standard	Core security (open-source tools) Customer-hosted Zero-knowledge encryption Basic audit logs (90 days) TIN authentication
Helium Professional	All Standard features, PLUS: Local users OR SSO 3 RBAC roles Extended audit logs (7 years) Advanced SIEM alerting Compliance reporting
Helium Enterprise	All Professional features, PLUS: SSO mandatory (6 roles) Blockchain audit log anchoring SOC 2 audit support Penetration testing coordination Advanced security options

This specification documents Helium Enterprise security capabilities. Enterprise security tool upgrades are optional and priced separately.

Important Notes

Security Architecture Philosophy:
Helium is designed with a zero-trust, zero-knowledge architecture where customer data security is paramount. All security measures are implemented to ensure WestMetro Limited cannot access, decrypt, or exfiltrate customer data under any circumstances.

Preview Document Scope:
This document contains Module 2 (Security & Compliance Architecture) only. Two additional documents are provided separately for evaluation:

- **Module 1: Executive Overview & Phased Roadmap** (separate document)
- **Complete Technical Specification: Modules 1-11** (provided upon formal engagement with WestMetro Limited)

For questions or to request complete documentation:

- Email: technical@westmetrong.com
- Phone: [contact number]

Helium Security Architecture Overview

Helium is built on zero-trust, zero-knowledge principles ensuring WestMetro Limited cannot access customer data under any circumstances.

Core Security Principles

1. Customer Data Sovereignty

- Customer-hosted deployment (your infrastructure only)
- Customer-managed encryption keys (WML cannot decrypt)
- Data never leaves customer environment
- Zero-knowledge architecture (WML has no access to keys or data)

2. Defense in Depth

- Multiple independent security layers
- No single point of failure in security architecture
- Compensating controls for each security layer
- Assume breach - design for containment and recovery

3. Zero-Trust Architecture

- Never trust, always verify - every request authenticated
- Least privilege access - minimum permissions required

- Continuous monitoring and validation
- Explicit verification at every layer

4. Comprehensive Auditability

- Immutable audit logs (90 days Standard, 7 years Professional/Enterprise)
- Real-time SIEM monitoring (Wazuh)
- Blockchain-anchored forensic proof (Enterprise)
- Complete traceability of all actions

5. Open-Source Security Stack

- Transparent, auditable codebase (available under NDA)
- Community-vetted security tools (Wazuh, Vault, PostgreSQL)
- No vendor lock-in or proprietary black boxes
- Independent security verification possible

Security Layers

Layer	Technologies	Protection
Application	OAuth 2.0 + MFA, RBAC (6 roles), Zod input validation, Rate limiting	Authentication, authorization, input sanitization
Data	AES-256 encryption, Field-level encryption (TINs, amounts), Per-customer isolation	Data protection at rest
Network	TLS 1.3, Kubernetes network policies, Firewall rules, VPN support	Data protection in transit
Monitoring	Wazuh SIEM, ELK logging, Prometheus metrics, Jaeger distributed tracing	Threat detection and response
Infrastructure	Customer-controlled, Vault key management, Zero WML access	Physical and logical security

---

Compliance & Certifications

Current Compliance:

- NDPR (Nigeria Data Protection Regulation) compliant
- FIRS e-invoicing mandate compliant
- Annual penetration testing by third-party security firms
- Continuous vulnerability management (CVE monitoring)

Available Certifications:

- SOC 2 Type II audit support (₦10M-₦12M one-time)
- ISO 27001 roadmap (2026)
- Custom compliance reports for regulated industries

Security Architecture Diagram

The following diagram illustrates Helium's complete security architecture, showing how all layers work together to provide defense-in-depth:

```
┌──────────────────────────────────────────────────────────────────────────┐
│                    CUSTOMER INFRASTRUCTURE                               │
│                     (You Deploy & Control)                               │
│                                                                          │
│  ┌──────────────────────────────────────────────────────────────────┐   │
│  │                        HELIUM                                    │   │
│  │         (Single Deployment - Internal Microservices)             │   │
│  │                                                                  │   │
│  │  ┌──────────────────────────────────────────────────────────┐   │   │
│  │  │ APPLICATION LAYER - Authentication & Authorization       │   │   │
│  │  │ • OAuth 2.0 + OIDC (SSO)     • MFA (TOTP, SMS, Email)    │   │   │
│  │  │ • RBAC (6 roles)             • JWT tokens                │   │   │
│  │  │ • Zod input validation       • Rate limiting (DDoS)      │   │   │
│  │  └──────────────────────────────────────────────────────────┘   │   │
│  │                            ↓                                     │   │
│  │  ┌──────────────────────────────────────────────────────────┐   │   │
│  │  │ API GATEWAY LAYER - Traffic Control                      │   │   │
│  │  │ • TLS 1.3 termination        • API rate limiting         │   │   │
│  │  │ • Request validation         • DDoS protection           │   │   │
│  │  │ • WAF rules                  • Certificate management    │   │   │
│  │  └──────────────────────────────────────────────────────────┘   │   │
│  │                            ↓                                     │   │
│  │  ┌──────────────────────────────────────────────────────────┐   │   │
│  │  │ SERVICE MESH - Internal Communications (Istio)           │   │   │
│  │  │ • Mutual TLS between services • Circuit breakers         │   │   │
│  │  │ • Load balancing              • Retry policies           │   │   │
│  │  │ • Traffic encryption          • Service authentication   │   │   │
│  │  └──────────────────────────────────────────────────────────┘   │   │
│  │         ↓                    ↓                    ↓             │   │
```

```
│  │  ┌──────────────┐    ┌──────────────┐    ┌──────────────┐          │ │
│  │  │   Queue      │    │   API        │    │   Worker     │          │ │
│  │  │  (RabbitMQ)  │    │  Services    │    │  Services    │          │ │
│  │  │              │    │              │    │              │          │ │
│  │  │ • Vault auth │    │ • Prisma ORM │    │ • Job proc   │          │ │
│  │  │ • TLS 1.3    │    │ • SQL inject │    │ • File proc  │          │ │
│  │  │ • HMAC msgs  │    │   prevention │    │ • FIRS API   │          │ │
│  │  │ • Net policy │    │ • Validation │    │ • Email      │          │ │
│  │  └──────────────┘    └──────────────┘    └──────────────┘          │ │
│  │                            ↓                                        │ │
│  │  ┌──────────────────────────────────────────────────────────┐      │ │
│  │  │ DATA LAYER - Encryption & Isolation                      │      │ │
│  │  │ • PostgreSQL (field-level encryption: TINs, amounts, PII)  │      │ │
│  │  │ • AES-256 encryption at rest                             │      │ │
│  │  │ • Customer-managed keys (HashiCorp Vault)                │      │ │
│  │  │ • Per-customer schema isolation (row-level security)     │      │ │
│  │  └──────────────────────────────────────────────────────────┘      │ │
│  │                            ↓                                        │ │
│  │  ┌──────────────────────────────────────────────────────────┐      │ │
│  │  │ MONITORING LAYER - SIEM & Observability                  │      │ │
│  │  │                                                          │      │ │
│  │  │  ┌──────────┐  ┌──────────┐  ┌──────────┐  ┌──────────┐ │      │ │
│  │  │  │  Wazuh   │  │   ELK    │  │Prometheus│  │  Jaeger  │ │      │ │
│  │  │  │  (SIEM)  │  │  Stack   │  │ (Metrics)│  │ (Trace)  │ │      │ │
│  │  │  │          │  │          │  │          │  │          │ │      │ │
│  │  │  │ Detect → Alert → Respond → Log → Report             │ │      │ │
│  │  │  └──────────┘  └──────────┘  └──────────┘  └──────────┘ │      │ │
│  │  │                                                          │      │ │
│  │  │  Security Events Flow (< 30 seconds response):           │      │ │
│  │  │  ① Wazuh detects anomaly (failed auth, port scan)        │      │ │
│  │  │  ② Correlates context (geo, time, user history)          │      │ │
│  │  │  ③ Fires alert (Slack, email, webhook)                   │      │ │
│  │  │  ④ Auto-response (block IP, lock account)                │      │ │
│  │  │  ⑤ Immutable log to ELK + blockchain anchor (Enterprise)  │      │ │
│  │  └──────────────────────────────────────────────────────────┘      │ │
│  │                                                                    │ │
│  │  ┌──────────────────────────────────────────────────────────┐      │ │
│  │  │ KEY MANAGEMENT - Customer Control                        │      │ │
│  │  │ • HashiCorp Vault (secrets storage, key rotation)        │      │ │
│  │  │ • Customer-generated encryption keys                     │      │ │
│  │  │ • Quarterly key rotation (automated)                     │      │ │
│  │  │ • Zero-knowledge: WML cannot access keys or decrypt data  │      │ │
│  │  └──────────────────────────────────────────────────────────┘      │ │
│  │                                                                    │ │
│  └────────────────────────────────────────────────────────────────────┘ │
│                                                                          │
│  ┌──────────────────────────────────────────────────────────────────┐   │
│  │ NETWORK LAYER - Perimeter Security                               │   │
│  │ • Kubernetes network policies (pod-to-pod isolation)             │   │
│  │ • Firewall rules (deny-all-by-default)                           │   │
│  │ • VPN/Private Link for ERP connectivity                          │   │
│  │ • No direct internet exposure (API gateway only)                 │   │
│  └──────────────────────────────────────────────────────────────────┘   │
```

```
│                                                                          │
└──────────────────────────────────────────────────────────────────────────┘
        ↑                                                  ↓
        │                                                  │
    ERP (API/SFTP)                                  FIRS (via Taxly)
    • TLS 1.3                                       • TLS 1.3
    • Certificate auth                              • OAuth tokens
    • Firewall whitelist                            • Rate limiting
```

Key Architectural Notes

Single Deployment Model:
Customer deploys ONE integrated platform (Helium), which contains multiple internal microservices:

- API gateway
- Application services
- Message queue (RabbitMQ) - internal component
- Database (PostgreSQL) - internal component
- Monitoring stack (Wazuh, ELK, Prometheus, Grafana)

Customer does **not** separately install, configure, or manage RabbitMQ or PostgreSQL—these are internal implementation details of Helium's architecture.

Zero-Knowledge Guarantee:
WestMetro Limited cannot access customer data because:

1. Encryption keys generated and managed by customer (Vault)
2. WML never has access to key material
3. Data encrypted at rest and in transit
4. Network logs prove no data exfiltration to WML servers
5. Source code available for audit (NDA basis)

Customer Control:

- All components run in customer infrastructure
- Customer manages Kubernetes cluster
- Customer controls network policies and firewall rules
- Customer manages encryption keys and rotation schedules
- Customer owns all data and audit logs

The sections below provide detailed breakdowns of each security layer.

MODULE 2: Security and Compliance Architecture

Table of Contents

2.1 Security Architecture Overview
2.2 Data Encryption
2.3 Network Security
2.4 Authentication & Access Control
2.5 Audit Logging & SIEM
2.6 Compliance Certifications
2.7 Vulnerability Management
2.8 Data Residency & Sovereignty
2.9 Disaster Recovery & Business Continuity
2.10 Security Add-Ons & Services
2.11 Internal Queue Security

2.1 Security Architecture Overview

Zero-Knowledge Architecture

Helium is architected from the ground up to ensure WestMetro Limited (WML) cannot access, decrypt, or exfiltrate customer data under any circumstances. This zero-knowledge model provides customers with complete data sovereignty while maintaining WML's ability to provide support and updates.

Core Security Principles

1. Zero-Trust Model

- Never trust, always verify - every request authenticated and authorized
- Least privilege access - minimum permissions required for each role
- Assume breach - design for containment and recovery
- Explicit verification - validate identity, device, and context

2. Defense in Depth

- Multiple layers of security controls
- No single point of failure in security architecture
- Compensating controls for each security layer
- Continuous monitoring and alerting at every level

3. Customer Data Sovereignty

- Customer-hosted deployment (your infrastructure only)
- Customer-managed encryption keys (stored in your Vault)
- Data never leaves customer environment
- WML cannot decrypt customer data under any circumstances

Five-Layer Proof System

Helium provides five independent layers of proof that WML cannot access customer data:

Layer 1: Customer-Managed Encryption Keys

- You generate and control all encryption keys in YOUR Key Vault
- WML never has access to key material
- You can rotate keys anytime → WML immediately loses all access
- **Proof**: Your key management audit logs show WML never accessed keys

Layer 2: Network Evidence

- Your firewall logs show all Helium outbound connections
- Only legitimate destinations: FIRS (via Taxly), your ERP
- No data exfiltration to WML servers
- **Proof**: Inspect firewall logs 24/7, TLS decrypt and verify payloads

Layer 3: Code Transparency

- Helium source code available for audit (NDA basis)

- Static analysis shows no data exfiltration logic
- Independent security firm can verify
- **Proof**: Third-party code audit report provided

Layer 4: Immutable Audit Logs

- Every Helium action logged with cryptographic signatures
- Logs show: what data accessed, by whom, when, why
- No log entries for "WML accessed invoice data" (because it never happens)
- **Proof**: Export audit logs anytime, blockchain-anchored for irrefutability (Enterprise)

Layer 5: Contractual Guarantee

- SLA includes substantial penalty for unauthorized data access
- Annual SOC 2 Type II audits verify controls (customer option)
- Customer right to audit WML anytime
- **Proof**: Signed contract + annual audit reports

2.2 Data Encryption

Encryption at Rest

Database Encryption:

- **Algorithm**: AES-256 (Advanced Encryption Standard)
- **Scope**: All sensitive data fields encrypted at column level
- **Implementation**: Helium's database layer (PostgreSQL) uses pgcrypto extension for field-level encryption
- **Key Management**: Customer-managed keys stored in HashiCorp Vault or cloud Key Vault

Encrypted Fields:

- Tax Identification Numbers (TINs)
- Email addresses
- Phone numbers
- Monetary amounts
- Invoice line item descriptions
- Buyer/supplier names and addresses

Database Isolation:

- Each customer has isolated database schema
- Physical data separation (no multi-tenancy at table level)
- Helium's internal connection pooling with per-customer credentials
- Row-level security policies enforce customer data boundaries

Encryption in Transit

TLS 1.3 Configuration:

- All network communications encrypted with TLS 1.3
- Certificate-based authentication for service-to-service communication
- Perfect forward secrecy enabled
- Strong cipher suites only (AES-GCM, ChaCha20-Poly1305)

Protected Communications:

- ERP → Helium: TLS 1.3 (API) or SFTP
- Helium → FIRS (via Taxly): TLS 1.3
- Helium → Buyers: Email with TLS, API with TLS 1.3
- Internal services: Mutual TLS via Istio service mesh

Key Management

HashiCorp Vault Integration:

- Industry-standard secrets management
- Encryption keys stored in Vault, never in code or config files
- Automatic key rotation (quarterly by default, customer-configurable)
- Audit trail for all key access

Customer Control:

- Customer generates initial encryption keys during deployment
- Customer can rotate keys anytime via Vault API
- Customer can revoke WML support access (Helium continues operating)
- Keys never leave customer infrastructure

Alternative: Cloud Key Vaults

- Azure Key Vault (for Azure deployments)

- AWS KMS (for AWS deployments)
- Google Cloud KMS (for GCP deployments)
- Same zero-knowledge model - WML has no access

2.3 Network Security

TLS Configuration

TLS 1.3 Enforcement:

- All communications use TLS 1.3 (TLS 1.2 deprecated)
- Certificate-based mutual authentication
- Perfect forward secrecy (PFS) enabled
- HSTS (HTTP Strict Transport Security) headers

Supported Cipher Suites:

- TLS_AES_256_GCM_SHA384
- TLS_CHACHA20_POLY1305_SHA256
- TLS_AES_128_GCM_SHA256

Weak ciphers explicitly disabled (no 3DES, RC4, MD5).

Kubernetes Network Policies

Pod-to-Pod Isolation:

- Default deny-all policy
- Explicit allow rules for required communications
- Namespace isolation (Helium pods cannot access other namespaces)
- Ingress and egress rules strictly defined

Example Policy:

- API gateway can receive traffic from internet (port 443 only)
- API gateway can connect to application services (internal only)
- Application services can connect to database (internal only)
- Database cannot initiate outbound connections

- Queue accessible only by API services and workers

Firewall Architecture

Perimeter Security:

- Cloud firewall (Azure NSG, AWS Security Groups, or customer firewall)
- Deny-all-by-default policy
- Explicit allow rules for:
    - HTTPS (443) from internet to API gateway
    - ERP connectivity (customer-defined IP ranges)
    - FIRS/Taxly API endpoints (TLS 1.3)
- All other traffic blocked

Internal Network Segmentation:

- DMZ for API gateway
- Application tier (no direct internet access)
- Data tier (no direct internet access)
- Management tier (administrative access only)

VPN and Private Connectivity

Enterprise Options:

- VPN tunnel for ERP-to-Helium communication
- Azure Private Link / AWS PrivateLink
- Dedicated network circuits (MPLS, SD-WAN)
- No public internet traversal for sensitive data

Email Security

Helium sends invoice notifications and acceptance reminders via email. Email security is implemented with tiered capabilities by edition.

Email Security Controls:

Authentication Standards:

- **SPF (Sender Policy Framework):** Authorizes Helium's mail servers
- **DKIM (DomainKeys Identified Mail):** Cryptographically signs outbound emails

- **DMARC (Domain-based Message Authentication):** Enforces authentication policies

Encryption in Transit:

- TLS 1.3 for all SMTP connections
- Mandatory encryption - plaintext SMTP rejected
- Certificate-based authentication for mail servers

Email Security by Edition:

Capability	Standard	Professional	Enterprise
Outbound Email	Plain text notifications TLS 1.2+ required	HTML templates SPF/DKIM configured Delivery tracking	DMARC enforcement Advanced templates Bounce management Anomaly detection
Authentication	TLS encryption only	SPF + DKIM	SPF + DKIM + DMARC
Monitoring	Basic delivery logs (90 days)	Failed delivery alerts (7 years)	Full email audit trail SIEM integration Phishing detection
Audit Logging	Basic (who, when, to whom)	Enhanced (delivery status, bounces)	Complete (headers, routing, anomalies)

Enterprise Email Security Features:

- **Phishing Protection:** Analyzes recipient engagement patterns to detect potential phishing attempts
- **Anomaly Detection:** Wazuh SIEM flags unusual email patterns (volume spikes, off-hours sending, geographic anomalies)
- **Email Audit Trail:** Every email logged immutably with full headers, delivery path, and recipient actions
- **Bounce Management:** Intelligent retry logic and CRM integration for failed deliveries

---

2.4 Authentication & Access Control

Authentication & Authorization by Edition

Helium provides tiered authentication and authorization capabilities:

Edition	Authentication	RBAC	Users	Cost
Standard	TIN + Password (shared credential)	❌ None Single login	1 shared login	Included
Professional	Local users OR SSO (OAuth/OIDC)	✅ 3 basic roles: • Admin • User • Read-only	Up to 25 users	Included
Enterprise	SSO mandatory (OAuth/OIDC) SAML optional	✅ 6 standard roles: • System Admin • Security Admin • Finance Manager • Invoice Processor • Auditor • Read-only	Unlimited users	Included
Enterprise + Advanced RBAC	SSO mandatory (OAuth/OIDC) SAML optional	✅ Unlimited custom roles • ABAC (attribute-based) • Time-based access • Role inheritance • Separation of duties	Unlimited users	+₦2M setup + ₦1.8M/year

SSO Integration Details

OAuth 2.0 / OIDC (Included in Professional & Enterprise):

- Modern authentication standard using JSON
- Supported identity providers:
  - Azure AD / Entra ID
  - Google Workspace
  - Okta
  - Auth0
  - Any OIDC-compliant IdP
- Configuration: 30 minutes via admin portal
- No additional cost

SAML 2.0 (Optional Add-On: ₦3.6M/year):

- Legacy authentication standard using XML
- Required for older identity providers (AD FS, IBM Tivoli, Oracle IAM)

- Common for government agencies and financial institutions with legacy infrastructure
- Configuration: 2-3 days (WML provides implementation support)
- Includes: Certificate management, encrypted assertions, single logout

Why SAML is an Add-On:
SAML 2.0 requires significantly more overhead than OIDC (X.509 certificate management, XML parsing, legacy protocol maintenance). Most modern organizations use OIDC (included). SAML is only needed for legacy systems or specific regulatory requirements.

Multi-Factor Authentication

MFA Options:

- TOTP (Time-based One-Time Password): Google Authenticator, Authy, Microsoft Authenticator
- SMS (text message codes)
- Email verification codes
- Hardware tokens (YubiKey, FIDO2)

MFA Enforcement:

- Standard: Optional (customer configures)
- Professional: Recommended for admins
- Enterprise: Mandatory for all users

Session Management

Session Security:

- JWT (JSON Web Token) based sessions
- Short-lived access tokens (15 minutes)
- Refresh token rotation
- Automatic session timeout (configurable: 15min - 8hr)
- Concurrent session limits (configurable per role)

Session Monitoring:

- Active session dashboard
- Remote session termination (admin capability)
- Suspicious session detection (geo-location, impossible travel)
- Session hijacking prevention (IP binding, user agent validation)

2.5 Audit Logging & SIEM

Comprehensive Audit Logging

What is Logged:

- All user actions (login, logout, invoice creation, approval, rejection)
- All API calls (timestamp, user, endpoint, parameters, response)
- All data access (who viewed/modified which invoices/buyers)
- All administrative actions (user creation, role changes, config updates)
- All security events (failed logins, MFA failures, suspicious activity)
- All system events (service starts/stops, errors, warnings)

Log Format:

- Structured JSON logs
- Cryptographically chained (tamper-detection)
- Immutable (cannot be modified after creation)
- Timestamped with high-precision NTP

Log Retention:

- Standard: 90 days
- Professional: 7 years
- Enterprise: 7 years (with blockchain anchoring)

SIEM Integration (Wazuh)

Real-Time Security Monitoring:
Wazuh SIEM provides 24/7 automated security monitoring and threat detection across all Helium components.

Detection Capabilities:

- Brute force attacks (multiple failed logins)
- Privilege escalation attempts
- Suspicious API usage patterns
- Data exfiltration attempts
- Malware and rootkit detection
- File integrity violations

- Network port scans
- Configuration changes

SIEM in Action: Suspicious Login Detection

Scenario: Attacker attempts credential stuffing attack

Response Flow (automated, < 30 seconds):

① **Detection (T+0 seconds):**

- Wazuh agent detects 5 failed login attempts in 2 minutes
- Same username, different passwords (credential stuffing pattern)

② **Correlation (T+5 seconds):**

- Wazuh correlates with user's historical login patterns
- User typically logs in 9am-5pm WAT, Monday-Friday
- Current attempt: 2:30am Sunday (anomaly detected)
- Geo-location shows impossible travel: Lagos → China in 10 minutes

③ **Alert Generation (T+10 seconds):**

- High-severity alert: "Impossible travel + credential stuffing"
- Alert sent via Slack, email, SMS (if configured)
- Alert includes: username, source IPs, timestamps, recommended actions

④ **Automated Response (T+15 seconds):**

- Account locked for 30 minutes
- Source IP blocked at firewall
- User notified via email: "Suspicious activity detected"
- Security team receives executive summary

⑤ **Immutable Logging (T+20 seconds):**

- Entire incident logged to ELK with cryptographic signature
- Log includes all attempts, geo-data, alerts, responses
- Log hash anchored to blockchain (Enterprise edition)

Total Response Time: 15 seconds from detection to account lockout

Human Intervention Required: None (fully automated)

This is SIEM in action: Detection, correlation, alerting, response, and logging happen automatically. Security teams focus on strategic threats while Wazuh handles tactical incidents.

Tamper-Proof Logging

Cryptographic Chaining:
Each log entry includes:

- Hash of previous log entry (blockchain-style chaining)
- Cryptographic signature (HMAC-SHA256)
- NTP timestamp (prevents backdating)

Tampering Detection:
If attacker modifies a log entry:

- Hash chain breaks (tampering detected)
- Signature validation fails
- Alert fires to security team
- Forensic investigation triggered

Blockchain Anchoring (Enterprise):

- Hourly log hashes anchored to Bitcoin blockchain via OpenTimestamps
- Provides legally admissible proof of log existence at specific time
- Cannot be backdated or forged
- Useful for litigation, compliance audits, forensic investigations

---

2.6 Compliance Certifications

Current Compliance

NDPR (Nigeria Data Protection Regulation):

- Data minimization (collect only required invoice data)
- Consent management (buyer acceptance workflow)
- Right to access (API for data export)
- Right to erasure (after legal retention period)
- Data breach notification (24-hour SLA)
- Data Protection Impact Assessments (DPIA) available

FIRS E-Invoicing Mandate:

- Full compliance with FIRS technical specifications

- UBL 3.0 JSON format
- Digital signatures and QR codes
- 72-hour acceptance tracking
- Audit trail requirements

Available Certifications

SOC 2 Type II Audit Support (₦10M-₦12M):

- For customer-hosted deployments requiring SOC 2 certification
- WML provides: gap assessment, documentation templates, evidence collection support, audit liaison
- Customer pays external auditor separately (₦15M-₦25M typical)
- Timeline: 3-6 months from engagement to completion

ISO 27001 (Roadmap - 2026):

- Information Security Management System (ISMS)
- WML pursuing certification for WML-hosted deployments
- Customer-hosted deployments can pursue independently (WML support available)

Annual Penetration Testing:

- WML's Helium software penetration tested annually by third-party security firms
- Results available to customers upon request
- Critical vulnerabilities patched within 48 hours, high within 7 days
- Coordination support available for customer-specific pen tests (₦500K coordination fee)

Industry-Specific Compliance

For Financial Institutions:

- PCI DSS considerations for payment data (if applicable)
- HSM integration support for FIPS 140-2 Level 3 (contact for pricing)
- Separation of duties enforcement (Advanced RBAC add-on)

For Healthcare:

- HIPAA considerations (if invoice data includes health information)
- Enhanced audit logging
- Breach notification procedures

For Government:

- SAML 2.0 integration for legacy IdPs (₦3.6M/year)
- Air-gapped deployment considerations (contact WML)
- Enhanced security monitoring (Dedicated SOC - custom pricing)

2.7 Vulnerability Management

SQL Injection Prevention

Helium implements four independent layers of protection against SQL injection attacks:

Layer 1: Prisma ORM

- Automatic parameterized queries - user input never treated as executable SQL code
- Database receives query template + separate parameters
- Attacks fail because input is treated as data, not code
- All database queries use Prisma ORM - no raw SQL except in rare, security-reviewed cases

Layer 2: Input Validation (Zod Schemas)

- All inputs validated against strict schemas before reaching database
- Type checking (string, number, date, etc.)
- Format validation (TIN format, email format, phone format)
- Range validation (amounts, dates, lengths)
- Malformed data rejected before query execution

Layer 3: Database Permissions

- Helium's database user has minimal permissions (SELECT, INSERT, UPDATE only)
- No DROP TABLE, ALTER TABLE, CREATE USER, or system catalog access
- Row-level security (RLS) ensures customer data isolation
- Each customer connection includes session variable limiting data access

Layer 4: Network Isolation

- Database not internet-accessible
- Firewall rules restrict access to Helium's application layer only
- No direct database connections from external systems

Verification:

- Annual penetration testing with sqlmap, Burp Suite, OWASP ZAP

- Code review enforces Prisma ORM usage
- Linting rules prevent raw SQL queries
- Third-party security audit reports available upon request

Result: SQL injection is effectively impossible - attacker would need to bypass all four independent layers simultaneously.

CVE Monitoring

Continuous Vulnerability Scanning:

- Daily scans of all Helium dependencies (npm, Docker images, OS packages)
- Automated CVE database updates
- Severity-based prioritization (Critical, High, Medium, Low)
- Automated Dependabot pull requests for security updates

Vulnerability Response SLA:

- Critical vulnerabilities: Patched within 48 hours
- High vulnerabilities: Patched within 7 days
- Medium vulnerabilities: Patched within 30 days
- Low vulnerabilities: Addressed in quarterly updates

Customer Notifications:

- Critical: Immediate email + Slack notification
- High: Email within 24 hours
- Medium/Low: Included in monthly security bulletin

Penetration Testing

Annual Third-Party Testing:

- Independent security firm conducts annual penetration testing
- Scope: APIs, web application, network infrastructure, authentication
- Methodology: OWASP Testing Guide, PTES
- Report provided to customers upon request (NDA required)

Customer-Specific Testing:

- Coordination support available for customer-hosted deployments (₦500K coordination fee)
- WML provides technical documentation, test accounts, and remediation support

- Customer pays penetration testing firm directly (₦3M-₦7M typical)

2.8 Data Residency & Sovereignty

Customer-Hosted Deployment Model

Default Deployment:

- Customer deploys Helium in their own infrastructure (on-premises or cloud)
- Customer owns and controls all data
- Customer chooses geographic location for data storage
- Customer defines data retention and backup policies

Customer Infrastructure Options:

- On-premises data center (Lagos, Abuja, Port Harcourt, etc.)
- Azure (West Africa, South Africa, or any region)
- AWS (any region)
- Google Cloud (any region)
- Hybrid (on-premises + cloud)

Data Flow & Storage

What Data Stays Where:

Customer Infrastructure (Your Control):

- All invoice data (TINs, amounts, descriptions, buyer/supplier info)
- Audit logs (all user actions, API calls, security events)
- Encryption keys (Vault)
- User credentials (hashed passwords, SSO tokens)
- All operational data

FIRS Systems (Required for Compliance):

- Invoice metadata (IRN, QR code, validation status)
- Required for e-invoicing mandate compliance
- Transmitted via TLS 1.3 through Taxly gateway

- No PII beyond what's required by FIRS regulations

WML Systems (Zero Customer Data):

- No customer data stored on WML servers
- No access to customer encryption keys
- Support tickets (if customer voluntarily shares sanitized data)
- Licensing and subscription management (customer ID, license keys)

NDPR Compliance

Data Protection Principles:

- Data minimization: Collect only required invoice data
- Purpose limitation: Data used only for e-invoicing compliance
- Storage limitation: Data retained per legal requirements, then deleted
- Integrity and confidentiality: Encryption, access controls, audit logs
- Accountability: Customer is data controller, WML is data processor (for support only)

Data Subject Rights:

- Right to access: API available for data export
- Right to rectification: Invoice correction workflows
- Right to erasure: After legal retention period (7 years)
- Right to portability: Data export in JSON/CSV format
- Right to object: Buyer acceptance/rejection workflow

2.9 Disaster Recovery & Business Continuity

Backup and Recovery

Customer Responsibility (Customer-Hosted):

- Database backups (recommended: daily full, hourly incremental)
- Vault backups (encryption keys)
- Configuration backups
- Kubernetes manifests and Helm charts

WML-Provided Tools:

- Backup scripts and automation (included)
- Disaster recovery runbook (included)
- Recovery testing procedures (included)

Recommended Backup Strategy:

- Primary backup: Same data center (different zone)
- Secondary backup: Different geographic location
- Tertiary backup: Cold storage (tape, S3 Glacier, Azure Archive)
- Retention: 7 years for invoice data, 90 days for operational logs

Recovery Time Objectives

RTO (Recovery Time Objective):

- Standard/Professional: < 4 hours (customer-managed)
- Enterprise with HA: < 15 minutes (automated failover)

RPO (Recovery Point Objective):

- Standard/Professional: < 1 hour (hourly backups)
- Enterprise with HA: < 5 minutes (continuous replication)

High Availability Architecture

For Enterprise customers requiring higher availability:

- Active-passive or active-active deployment
- Automatic failover between availability zones
- Database replication (synchronous or asynchronous)
- Load balancing across multiple instances

Note: High availability architecture, geographic redundancy, and multi-region deployment are covered in Module 9 (Operations), not as security add-ons.

2.10 Security Add-Ons & Services

Helium Enterprise includes comprehensive security capabilities designed for regulated environments. The following optional add-ons extend security for specialized regulatory, compliance, or operational requirements.

Included in Helium Enterprise Base:

- OAuth 2.0 + OIDC SSO integration
- Standard RBAC (6 roles)
- 7-year audit log retention
- Wazuh SIEM with real-time alerting
- Annual vulnerability scanning
- Blockchain audit log anchoring (hourly)
- Business hours support (8am-6pm WAT, Mon-Fri)
- 99.9% uptime SLA

---

1. SAML 2.0 Integration

Cost: ₦3.6M/year
When Needed: Legacy identity providers requiring SAML instead of OIDC

Enterprise includes OAuth 2.0/OIDC (modern, JSON-based) for SSO integration with Azure AD, Google Workspace, Okta, Auth0, and any OIDC-compliant IdP. Configuration takes 30 minutes via admin portal.

SAML 2.0 is an optional add-on for legacy systems (AD FS, IBM Tivoli, Oracle IAM) or organizations with regulatory SAML requirements. Includes:

- Certificate management and rotation
- Encrypted assertions
- Single logout (SLO)
- Implementation support (2-3 days)

Most modern organizations use OIDC (included). SAML is only needed for legacy infrastructure or specific compliance requirements.

---

2. SOC 2 Type II Audit Support

Cost: ₦10M-₦12M (one-time)
When Needed: Customer-hosted deployments requiring SOC 2 certification

Important Distinction:

- **WML-Hosted Helium:** WML obtains SOC 2 certification (WML's cost)
- **Customer-Hosted Helium:** Customer obtains certification if needed (customer's responsibility)

What This Add-On Provides:

WML provides support services to help customer achieve SOC 2 certification. Customer pays external auditor separately (₦15M-₦25M typical).

Included Services:

- Gap assessment against SOC 2 requirements (1-2 weeks)
- Documentation templates (security policies, procedures, incident response plans)
- Evidence collection support (log collection, access reviews)
- Audit liaison (respond to auditor questions about Helium architecture)

Timeline: 3-6 months from engagement to audit completion

Who Needs This: Organizations in regulated industries (finance, healthcare, government) or those selling to enterprise customers requiring SOC 2 certification.

---

3. Penetration Testing Coordination Support

Cost: ₦500K (WML coordination fee)
Additional Cost: ₦3M-₦7M (customer pays pen test firm directly)

What's Included in Helium Base:
WML's Helium software is penetration tested annually by third-party security firms. Results available to customers upon request.

What This Add-On Provides:

For customer-hosted deployments requiring independent penetration testing of their specific installation, WML provides:

- List of pre-vetted Nigerian and international pen test firms
- Scoping assistance (APIs, network, application, infrastructure)
- Technical architecture documentation
- Test account setup with appropriate permissions
- Coordination of testing windows

- Review of findings (distinguish Helium vs infrastructure issues)
- Remediation support for Helium-specific findings

Timeline: 2-4 weeks from engagement to final report

Who Needs This: Organizations with security policies requiring annual penetration testing, regulated industries, government agencies.

---

4. Advanced RBAC (Custom Roles)

Cost: ₦2M setup + ₦1.8M/year
When Needed: Complex organizations requiring granular permission controls

Standard RBAC (Included):

- Standard: No RBAC (shared TIN login)
- Professional: 3 basic roles (Admin, User, Read-only)
- Enterprise: 6 standard roles (System Admin, Security Admin, Finance Manager, Invoice Processor, Auditor, Read-only)

Advanced RBAC (Add-On for Enterprise only):

Features:

- Unlimited custom roles specific to organizational structure
- Attribute-Based Access Control (ABAC) - permissions based on user attributes (department, location, cost center)
- Time-based access (temporary permissions, scheduled access)
- Role inheritance (hierarchical roles)
- Separation of duties enforcement (prevent conflicts of interest)

Example Use Cases:

- "Regional Finance Manager - North" (can process invoices for northern states only)
- Dynamic policies: "Can approve invoices if amount < user's approval limit"
- Auditor access only during audit period
- Prevent same user from creating and approving invoices

Implementation: Discovery (1 week) + role design (2-3 weeks) + testing (1 week) + training (1 week)

Who Needs This: Large enterprises (500+ employees), complex organizational structures, regulated industries with separation of duties requirements.

---

5. Dedicated Security Operations Center (SOC)

Cost: Custom pricing (contact WML)
When Needed: Large enterprises requiring 24/7 security monitoring

Standard Security Monitoring (Included):

- Wazuh SIEM with automated alerting
- Business hours support (8am-6pm WAT, Mon-Fri)
- Critical alerts escalated to customer security team

Dedicated SOC (Add-On):

For large enterprises requiring around-the-clock human security monitoring, WML offers dedicated SOC services with custom pricing based on:

- Number of Helium instances monitored
- Alert volume and complexity
- Response time requirements (5min, 15min, 1hr)
- On-site vs remote SOC

Typical SOC Services:

- 24/7/365 human security analysts monitoring Helium
- Real-time threat detection and response
- Incident investigation and forensics
- Quarterly security assessments
- Executive security reporting

Typical Pricing Range: ₦72M+/year (enterprise-scale deployments)

Note: This is mentioned for completeness. Most customers do not require dedicated SOC. Contact WML for detailed pricing and scoping.

---

6. Hardware Security Module (HSM) Integration

Cost: Contact WML for pricing
When Needed: FIPS 140-2 Level 3 compliance requirements

Standard Key Management (Included):

- HashiCorp Vault (software-based key storage)
- Customer-managed encryption keys
- FIPS 140-2 Level 1 compliant (software)

HSM Integration (Add-On):

For organizations requiring hardware-based key protection (banking, payment processing, government), Helium can integrate with hardware security modules:

Supported HSMs:

- Thales Luna Network HSM
- Azure Dedicated HSM
- AWS CloudHSM (for AWS deployments)

What Customer Provides:

- HSM hardware (customer purchases: ₦15M-₦50M)
- Network connectivity to HSM
- HSM administration

What WML Provides:

- Integration implementation (Helium → HSM)
- Key ceremony support
- Configuration and testing
- Documentation

Compliance: FIPS 140-2 Level 3 certified key storage, keys never leave HSM

Who Needs This: Banks, payment processors, financial institutions with FIPS 140-2 Level 3 requirements.

---

7. Blockchain Audit Log Anchoring

Professional Edition: ₦1M/year (₦83K/month)
Enterprise Edition: Included (no additional cost)

Provides irrefutable, legally admissible proof that audit logs existed at a specific point in time and have not been tampered with.

How It Works:

- Helium generates cryptographic hash of audit log every hour
- Hash submitted to OpenTimestamps service
- Hash included in Bitcoin blockchain block
- Timestamp proof stored with audit log

Use Cases:

- Legal disputes (prove invoice was created at specific time)

- Forensic investigations (prove logs weren't backdated)
- Compliance audits (demonstrate log integrity)
- Litigation support (legally admissible evidence)

Why Blockchain?

Blockchain provides two critical properties:

1. **Immutability:** Once in blockchain, timestamp cannot be changed
2. **Independence:** Bitcoin blockchain is independent third party (not controlled by you or WML)

Complementary to SIEM:

- **SIEM (Wazuh):** Real-time threat detection ("Is something bad happening now?")
- **Blockchain:** Forensic proof ("Can I prove what happened in the past?")

SIEM detects threats in real-time. Blockchain proves logs weren't tampered with later. They serve different but complementary purposes.

Availability:

- **Enterprise:** Included (no additional cost)
- **Professional:** Available as add-on (₦1M/year)
- **Standard:** Not available

Security Add-Ons Summary

Add-On	Professional	Enterprise	Use Case
SAML 2.0 Integration	₦3.6M/year	₦3.6M/year	Legacy identity providers
SOC 2 Audit Support	₦10M-₦12M	₦10M-₦12M	Regulatory compliance
Pen Test Coordination	₦500K	₦500K	Independent security validation
Advanced RBAC	Not available	₦2M + ₦1.8M/yr	Complex permission needs
Dedicated SOC	Not available	Custom pricing	24/7 security monitoring
HSM Integration	Not available	Custom pricing	FIPS 140-2 Level 3
Blockchain Anchoring	₦1M/year	Included	Forensic log integrity

---

What's NOT Included (By Design)

The following items are **not** security add-ons because they belong elsewhere:

Moved to Module 9 (Operations):

- Geographic redundancy and multi-region deployment
- High availability architecture
- Disaster recovery configuration

Moved to Module 10 (Implementation):

- 24/7 support (operational support, not security)
- Custom ERP connectors
- White-label deployment
- Custom compliance reports

Customer-Managed (Customer-Hosted Model):

- Extended data retention (customer configures storage)
- Backup schedules (customer manages infrastructure)
- Network redundancy (customer's network architecture)

Choosing the Right Add-Ons

Most Customers Need: None (Helium Enterprise base includes comprehensive security)

Consider SAML 2.0 if:

- Your identity provider doesn't support OIDC
- Government agency with legacy AD FS
- Regulatory requirement to use SAML

Consider SOC 2 Support if:

- You're in a regulated industry (finance, healthcare)
- Your customers require SOC 2 certification
- You're pursuing enterprise sales

Consider Pen Testing if:

- Your security policy requires annual testing
- You're in banking/finance/government
- You need independent validation

Consider Advanced RBAC if:

- 500+ employees
- Complex approval hierarchies
- Separation of duties requirements

Consider HSM if:

- Banking/payment processing
- FIPS 140-2 Level 3 mandate
- Ultra-high-value transactions

Blockchain Anchoring:

- Included in Enterprise (use it!)
- Consider for Professional if legal disputes likely

Dedicated SOC:

- Only for very large enterprises
- Limited internal security capability
- Critical infrastructure

For questions about security add-ons or to discuss your specific requirements:

WestMetro Limited Security Team
Email: info@westmetrong.com
Phone: 0803 364 8169

2.11 Internal Queue Security

Helium includes an internal message queue subsystem for reliable invoice processing and asynchronous task handling. This queue is an internal component of Helium's architecture, implemented using RabbitMQ.

Architectural Note

It's important to understand that RabbitMQ is **not** a separate system that Helium integrates with—it's an **internal microservice within Helium's deployment**.

When you deploy Helium, you deploy one integrated platform that includes:

- API gateway

- Application services
- Message queue (RabbitMQ) - internal component
- Database (PostgreSQL) - internal component
- Monitoring stack (Wazuh, ELK, Prometheus, Grafana)

You do **not** separately install, configure, or manage RabbitMQ. It's part of Helium's internal architecture.

Queue Security Controls

1. Internal Authentication

Queue credentials are managed internally by Helium and stored in HashiCorp Vault:

- Queue username and password generated during Helium deployment
- Credentials stored in Vault, never in configuration files
- Credentials rotated quarterly (automated)
- No external access to queue credentials

Customer Perspective: You never see or manage RabbitMQ credentials. Helium handles this internally.

2. Service Mesh Encryption

All communication between Helium's internal services (API → Queue → Workers) is encrypted via Istio service mesh:

- TLS 1.3 for all inter-service communication
- Mutual TLS (mTLS): Both client and server authenticate
- Certificate-based authentication (no passwords)
- Certificate rotation: Every 90 days (automated)

What This Prevents:

- Attackers cannot intercept messages between services
- Attackers cannot impersonate internal services
- Even if someone gains access to Kubernetes cluster, they cannot read queue messages

3. Network Isolation

The message queue is isolated at the network level via Kubernetes network policies:

- Queue is not accessible from internet
- Queue is not accessible from other Kubernetes namespaces
- Only Helium's internal services can access queue (API services and workers)
- No external integration points

4. Message Integrity

All messages in the queue include HMAC (Hash-based Message Authentication Code) signatures to prevent tampering:

Before processing a message, workers:

1. Recalculate HMAC signature
2. Compare with message signature
3. Reject message if signatures don't match

What This Prevents:

- Attackers cannot inject malicious messages into queue
- Attackers cannot modify messages in transit
- Messages cannot be replayed (timestamp validation)

Monitoring and Alerting

Queue security events are monitored by Wazuh SIEM:

Alerted Events:

- Failed authentication attempts to queue
- Unusual message volume (potential DoS attack)
- Messages rejected due to invalid HMAC
- Queue depth exceeding thresholds
- Service attempting to access queue without proper credentials

Example Alert: "Unusual queue activity: 1000 messages/sec (normal: 10/sec)"

Customer Responsibilities

What Customer Manages:

- Kubernetes cluster security (if customer-hosted)
- Network policies (if customized beyond Helium defaults)
- Infrastructure security (compute, storage)

What Customer Does NOT Manage:

- RabbitMQ installation or configuration
- Queue credentials (Helium manages internally)

- Queue monitoring (Helium's monitoring stack handles this)
- Queue upgrades (part of Helium upgrades)

Summary: Queue as Internal Component

Aspect	Traditional "Integration"	Helium's Approach
Installation	Customer installs RabbitMQ separately	RabbitMQ included in Helium deployment
Configuration	Customer configures queues, exchanges, bindings	Helium configures automatically
Credentials	Customer manages queue passwords	Helium manages internally (Vault)
Monitoring	Customer sets up separate monitoring	Helium's monitoring stack includes queue
Upgrades	Customer upgrades RabbitMQ independently	Queue upgraded with Helium platform
Security	Customer secures RabbitMQ separately	Queue security integrated into Helium

Bottom Line: From a security perspective, you're securing **one platform (Helium)**, not multiple separate systems. The fact that Helium uses RabbitMQ internally is an implementation detail, not a separate security domain.

End of Module 2

Document Statistics:

- Module: 2 of 11
- Version: 3.1
- Pages: ~30
- Last Updated: November 2025

Related Documents:

- Module 1: Executive Overview & Phased Roadmap (separate document)
- Complete Technical Specification: Modules 3-11 (provided upon engagement)

For Questions or Complete Documentation:
Contact: info@westmetrong.com

© 2025 WestMetro Limited. All Rights Reserved.

This document contains proprietary and confidential information. Unauthorized distribution, reproduction, or disclosure is strictly prohibited. This document may be shared with prospective customers under NDA for evaluation purposes.